

FamilySync

Report di Sicurezza

Scansione e interventi del 4 agosto 2026 • familysync.eu

In sintesi

È stata eseguita una scansione di sicurezza completa dell'applicazione (backend, autenticazione, pagamenti, feed pubblici). Sono stati individuati 8 punti deboli. I due più urgenti nella configurazione e nei feed calendario sono già stati corretti e portati nel codice; le correzioni per gli accessi tra famiglie diverse (IDOR) sono pronte e in fase di integrazione; il rafforzamento dei token di accesso è in lavorazione.

Cosa è stato già corretto

1. Protezione del browser (Content Security Policy)

Prima: la protezione CSP era completamente disattivata, lasciando la web app più esposta ad attacchi di tipo XSS (script malevoli iniettati nella pagina). Ora: il server invia regole rigorose che permettono al browser di caricare script solo dal nostro dominio, bloccano iframe e oggetti esterni e limitano le connessioni a quelle necessarie (API, RevenueCat).

2. Iniezione nei feed calendario pubblici (ICS)

Prima: un carattere speciale (\r) inserito nel titolo o nella descrizione di un evento poteva 'spezzare' il file calendario pubblico e iniettare righe arbitrarie nel feed. Ora: tutti i caratteri di controllo vengono rimossi o resi innocui, con test automatici a garanzia.

3. Foto pubbliche servite in modo controllato

Le foto pubbliche (ricette e avatar) sono ora servite con un'intestazione dedicata che ne consente la visualizzazione dalle anteprime, mentre tutti gli altri file caricati restano protetti da autenticazione.

Correzioni pronte, in fase di integrazione

Accessi incrociati tra famiglie (BOLA / IDOR)

- Aggiornamento segnalazioni moderazione: la modifica filtrava solo per ID della segnalazione, non per famiglia — un admin poteva modificare segnalazioni di altre famiglie.
- Archiviazione suggerimenti AI: stesso problema — un membro poteva archiviare suggerimenti di altre famiglie.

Regola adottata: ogni modifica o cancellazione su dati di famiglia deve filtrare anche per famiglia direttamente nella query al database, non solo nei controlli d'ingresso.

In lavorazione

Sicurezza di token e autenticazione

- Il cambio password non invalida i token di accesso già emessi (validi fino a 7 giorni): verrà introdotta la revoca.
- La protezione anti-riutilizzo dei codici di login Google/Apple è per-istanza: verrà spostata su stato condiviso (database).
- Il login non ha un limitatore dedicato contro i tentativi ripetuti di password: verrà aggiunto.

Altri punti emersi (rischio più basso)

- Registrazione tramite link famiglia: l'email viene marcata come verificata senza prova di possesso

— prevista email di verifica.

- In ambiente di sviluppo alcuni log contengono link di verifica/reset: solo dev, ma da ridurre.
- Le chiavi RevenueCat visibili nella configurazione sono chiavi pubbliche del SDK mobile: non sono segreti.

Conclusione

Nessuna delle vulnerabilità trovate risulta sfruttata. Le due correzioni più importanti sono già attive nel codice; per essere efficaci sul sito pubblico serve una nuova pubblicazione. Le attività rimanenti sono tracciate come task di progetto e verranno completate a breve.

Report generato automaticamente il 4 agosto 2026 sulla base della scansione di sicurezza e del modello delle minacce (threat_model.md).